

Beyond Taint

Structural invariants and machine-checkable witnesses for authorization, state-cycle, and trust-topology flaws

VALEN Project

Typed IR · Lean 4 · GLMY · Z3 witnesses

2026

Five contributions

- ① A **measured boundary** on geometric priors for injection SAST.
- ② An **authorization invariant**, mechanized in Lean 4 and made operational (BOLA/IDOR detector + Z3 ownership witness).
- ③ Evidence that **directed path homology** beats symmetrized homology for destructive-cycle detection.
- ④ A **measured neuro-symbolic arbitration boundary**.
- ⑤ A **trust-topology analysis** for IAM / lateral movement.

System: one typed IR, five layers

Layer	Structure	Contribution
Algebraic	privilege function $F : V \rightarrow \mathbb{N} + \text{auth edges}$	authorization invariant
Spectral	Fiedler cut	trust boundaries
Topological	GLMY directed H_1	state cycles
Geometric	Forman–Ricci κ_F	privilege bridges
Formal	Z3 + Lean 4	machine-checkable witnesses

Six adapters (Python, Java, binary, OpenAPI, IAM, IIm-agent) $\rightarrow$ one graph, shared Python $\leftrightarrow$ Rust.

C1 — The boundary on geometric priors

- **Question:** do spectral/topological/geometric invariants add information over taint for injection prioritization?
- **Measured on OWASP Benchmark 1.2 (2740 cases):** no.
- taint MRR 0.894 vs. fused field 0.872 ($p = 5 \times 10^{-5}$); spectral 0.496, topological 0.500 (chance), curvature 0.376.
- A flat servlet has no such structure; taint is near-optimal there.
- **Contribution:** a rigorous, falsifiable answer that redirects effort to where structure *is* the signal.

C2 — Authorization, mechanized and operational

- $F : V \rightarrow \mathbb{N}$, auth edges $E_A = \{(u, v) : F(u) < F(v)\}$; no_auth_bounded mechanized in Lean 4.
- BOLA/IDOR detector: ungated user-controlled resource access.
- **Z3 ownership witness**: $\text{SAT}(\text{owner}(id) \neq \text{session})$.
- login_required (authentication) does *not* block BOLA — only an object-level owner predicate does.
- **Real data (crAPI)**: 9/9 BOLA/BFLA recovered, recall 1.0, precision 0.90; missing-auth check scores 0 (all are authenticated).

C3 — Directed path homology

- Symmetrization is lossy both ways: a 2-cycle collapses (missed), a filled triangle becomes a false cycle.
- GLMY recovers the concrete β_1 generator.
- **Measured (12 state graphs):** recall 1.0 / precision 0.75 vs. undirected 0.5 / 0.5.
- GLMY H_1 = path-space holes $\supset$ feedback cycles: high recall, necessary-not-sufficient.

C4 — The neuro-symbolic arbitration boundary

- LLM *proposes* a structured spec; Z3 *disposes* it.
- **Measured (38 files, 29 findings):** detection/ranking agreement 0.974 (LLM-independent); CWE changes 28% (interpretation).
- Spec-mining (8 snippets): 0.5 token recall, 0 hallucination.
- **Contribution:** an architecture + its measurement, not a claim.

C5 — Trust-topology analysis

- Identity/permission graph: users, roles, trust policies, services.
- **Fiedler cut** surfaces trust-boundary crossings.
- **Forman–Ricci** isolates the privilege bridge (the attacker's pivot).
- Z3 resolves the role-assumption combinatorics.

Measured results at a glance

Contribution	Result
C1 boundary	taint 0.894 vs. field 0.872 ($p = 5 \times 10^{-5}$)
C2 authorization	crAPI recall 1.0, precision 0.90, F1 0.947
C3 directed homology	0.75/1.0 vs. undirected 0.5/0.5
C4 arbitration	detection/ranking 0.974; CWE 28%
C5 trust topology	privilege bridge $\kappa_F = -1$

Limitations (reported, not hidden)

- BOLA/IDOR: one real API + a curated corpus, not a benchmark.
- The structural detector over-approximates (sanitized/parameterized).
- Z3 witnesses hold under the *modeled* semantics, not end-to-end.
- GLMY H_1 is necessary, not sufficient.

- The productive role of structural invariants in security is *verification* of authorization, state, and trust properties — not prioritization of injection sinks.
- All of it over one typed IR, emitting machine-checkable witnesses.

Map the artifact as a space — verify the invariant.